SOCIAL ENGINEERING

Know the Threats. Beat the Threats.

An Ethical Hacking Awareness Session

CONFIDENTIAL — FOR TRAINING PURPOSES ONLY

SESSION AGENDA

01 **What Is Social Engineering?**

The human attack surface

02 **8 Attack Types with Real Examples**

Phishing, pretexting, baiting, tailgating, quid pro quo, vishing, spear phishing, watering hole

03 **Live Demonstrations**

See how easy it is to fall for these

04 **Defence Strategies**

Practical steps to protect yourself and the organisation

05 **Q&A + Discussion**

Share your own experiences

WHAT IS SOCIAL ENGINEERING?

The art of manipulating people into performing actions or divulging confidential information. It exploits human psychology — not technical vulnerabilities.

Trust

People want to help and be cooperative

Fear

Urgency and threats override logic

Curiosity

Free stuff and mystery lure victims

Authority

People obey perceived authority figures

90% of data breaches involve a social engineering component — Verizon DBIR

01 PHISHING

WHAT IS IT?

Mass fraudulent emails or messages impersonating trusted entities to harvest credentials or deliver malware.

SCENARIO: You receive an email from "IT-Support@yourcompany.co" (note the .co, not .com) saying your password expires in 2 hours. There's a big red button: "Reset Password Now." The link takes you to a pixel-perfect clone of your company's login page — but the URL is yourcompany-reset.phishsite.com. You enter your credentials, and the attacker now has your real password.

01 PHISHING

RED FLAGS & DEFENCE

RED FLAGS

- Slight domain misspelling (.co vs .com)
- Artificial urgency ("2 hours")
- Hover over links — URL doesn't match
- Generic greeting ("Dear User")

DEFENCE

Always verify the sender domain. Hover before you click. Use a password manager — it won't auto-fill on fake domains.

FACILITATOR TIP: Ask learners if they've ever encountered something similar. Share anonymised real incidents if available.

02 PRETEXTING

WHAT IS IT?

An attacker fabricates a believable scenario (pretext) to build trust and extract information or access.

SCENARIO: You get a call from someone claiming to be from your company's IT audit team. They say: "We've detected unusual login activity on your account during a routine compliance check. I need to verify your identity — can you confirm your employee ID, email address, and the last four digits of your national insurance number?" They already know your name and department from LinkedIn.

02 PRETEXTING

RED FLAGS & DEFENCE

RED FLAGS

- Caller already knows partial info (from OSINT)
- Requests sensitive details to 'verify' identity
- Creates urgency with compliance/audit framing
- You can't verify their identity in return

DEFENCE

Hang up and call back via official company directory. Never confirm sensitive info to inbound callers.

FACILITATOR TIP: Ask learners if they've ever encountered something similar. Share anonymised real incidents if available.

03 BAITING

WHAT IS IT?

Leaving physical or digital bait (infected USB, free download) to exploit curiosity.

SCENARIO: In the car park, you find a USB drive labelled "Q4 Salary Review — CONFIDENTIAL." Curiosity gets the better of you — you plug it into your work laptop. It auto-runs a script that installs a reverse shell, giving the attacker remote access to your machine and, through it, the corporate network. In tests, 45-98% of dropped USBs get plugged in.

03 BAITING

RED FLAGS & DEFENCE

RED FLAGS

- Unsolicited physical media in accessible areas
- Labels designed to trigger curiosity
- "Too good to be true" digital downloads
- No known owner or source

DEFENCE

Never plug in unknown devices. Report found media to security. Disable USB auto-run via group policy.

FACILITATOR TIP: Ask learners if they've ever encountered something similar. Share anonymised real incidents if available.

04 TAILGATING

WHAT IS IT?

Physically following an authorised person through a secured entrance without proper credentials.

SCENARIO: An attacker wearing a courier uniform arrives at your office entrance carrying several large boxes. They look like they're struggling and say: "Could you hold the door? I've got a delivery for the third floor." You hold the door — they walk straight past reception with no badge, no sign-in. Once inside, they can access meeting rooms, unlocked workstations, or plant rogue devices.

04 TAILGATING

RED FLAGS & DEFENCE

RED FLAGS

- Someone without visible ID asks to hold the door
- Carrying items that make badging difficult
- Claims to be a delivery, contractor, or new starter
- Avoids eye contact with security

DEFENCE

Politely ask for ID. Offer to call reception for them.

Never hold secure doors for strangers.

FACILITATOR TIP: Ask learners if they've ever encountered something similar. Share anonymised real incidents if available.

05 QUID PRO QUO

WHAT IS IT?

Offering a service or benefit in exchange for information or access.

SCENARIO: You receive a call: "Hi, I'm from the IT helpdesk. We're rolling out a new system update that will speed up your computer significantly. I just need your login credentials to push the patch remotely." The attacker calls dozens of employees — eventually someone is having a slow day and happily shares their details for the promise of a faster machine.

05 QUID PRO QUO

RED FLAGS & DEFENCE

RED FLAGS

- Unsolicited offer of tech support
- Requires your credentials to 'help'
- No ticket or reference number
- Urgency or limited-time framing

DEFENCE

Legitimate IT never needs your password. Verify through official channels. If it sounds too helpful, be suspicious.

FACILITATOR TIP: Ask learners if they've ever encountered something similar. Share anonymised real incidents if available.

06 VISHING

WHAT IS IT?

Voice phishing — phone calls impersonating trusted institutions to extract sensitive information.

SCENARIO: Your phone rings — caller ID shows your bank's name (spoofed). A professional voice says: "We've detected a suspicious £2,000 transfer from your account. For security, I need to verify your account number, sort code, and the one-time code we just sent to your phone." The "one-time code" is actually a real 2FA code the attacker triggered — if you read it out, they complete the fraudulent transfer.

06 VISHING

RED FLAGS & DEFENCE

RED FLAGS

- Inbound call claiming to be your bank
- Asks for one-time codes or PINs
- Caller ID can be spoofed
- High pressure — "Act now or lose money"

DEFENCE

Hang up. Call the number on the back of your card. Banks will never ask for OTPs or PINs over the phone.

FACILITATOR TIP: Ask learners if they've ever encountered something similar. Share anonymised real incidents if available.

07 ◎ SPEAR PHISHING

WHAT IS IT?

Highly targeted phishing aimed at a specific individual using personal information gathered from OSINT.

⚠

SCENARIO: The CFO receives an email from what appears to be the CEO's personal email (gathered from a conference programme). It references a board discussion from last week (details found in a leaked board pack) and says: "Can you urgently wire £180,000 to this account for the acquisition deposit? Keep this confidential until the announcement." The personalisation and context make it extremely convincing.

07 SPEAR PHISHING

RED FLAGS & DEFENCE

RED FLAGS

- Highly personalised — uses names, events, insider terms
- Requests financial action or sensitive data
- Sent from personal or slightly altered email
- Stresses urgency and confidentiality

DEFENCE

Verify out-of-band (call or in-person). Establish code words for financial approvals. Train high-value targets.

FACILITATOR TIP: Ask learners if they've ever encountered something similar. Share anonymised real incidents if available.

08 WATERING HOLE

WHAT IS IT?

Compromising a website frequently visited by the target group, infecting visitors passively.

SCENARIO: Attackers identify that your engineering team regularly visits a niche industry forum for firmware updates. They exploit a vulnerability in the forum's CMS and inject malicious JavaScript. When any of your engineers visit the site, the script silently fingerprints their browser and drops a zero-day exploit, giving the attacker a foothold into your network — all without a single email being sent.

08 WATERING HOLE

RED FLAGS & DEFENCE

RED FLAGS

- Unusual behaviour on regularly visited sites
- Unexpected download prompts or pop-ups
- Browser warnings about certificates or scripts
- Compromised sites may look completely normal

DEFENCE

Keep browsers and plugins updated. Use network segmentation. Monitor DNS/traffic anomalies. Employ endpoint detection and response.

FACILITATOR TIP: Ask learners if they've ever encountered something similar. Share anonymised real incidents if available.

KEY TAKEAWAYS

1. Verify before you trust — always confirm identity through official channels
2. Hover before you click — inspect every link, every time
3. Slow down — urgency is the attacker's best weapon
4. Report everything — even near-misses help the security team
5. It's OK to say no — politeness should never override security
6. Assume you're a target — because you are

SESSION DELIVERY GUIDE

(Hidden slide — for facilitator reference only)

Duration: 60-90 minutes (adjust based on group size and discussion)

Format: Interactive — encourage questions after each attack type

Live demo ideas: Send a (safe) test phishing email beforehand; show a caller ID spoof tool; demonstrate URL inspection in browser

Engagement: Use polls ("Have you ever clicked a suspicious link?") and pair discussions

Follow-up: Schedule a simulated phishing test 2-4 weeks after the session to reinforce learning

Materials: Share this deck + a one-page cheat sheet summarising red flags

STAY VIGILANT

The best firewall is an informed human.

Questions? Discussion? Share your stories.